

● ACTIVE INCIDENT

# CYBER SECURITY INCIDENT RESPONSE & SOC ANALYSIS REPORT

Multi-Vector Attack: Brute Force + Malware Infection + Data Exfiltration Attempt

|                 |                                                     |
|-----------------|-----------------------------------------------------|
| Incident ID:    | INC-2026-0312                                       |
| Organization:   | NovaTech Systems Ltd.                               |
| Incident Type:  | Multi-Vector — Brute Force + Malware + Exfiltration |
| Severity:       | CRITICAL — P1                                       |
| Detection Date: | March 12, 2026 — 02:47 UTC                          |
| Report Status:  | FINAL — Post-Incident Review                        |
| Lead Analyst:   | SOC Tier-2 Analyst                                  |

# 1. Executive Summary

On March 12, 2026 at 02:47 UTC, the Security Operations Center (SOC) of NovaTech Systems Ltd. detected a coordinated, multi-vector cyber attack targeting the organization's corporate network. The incident began with an automated brute-force campaign against the VPN gateway, escalated to malware deployment on two compromised endpoints, and culminated in an attempted data exfiltration to a command-and-control (C2) server located in Eastern Europe.

The SOC team detected, contained, and eradicated the threat within 6 hours and 42 minutes of initial detection. Affected systems were restored to operation within 18 hours. No confirmed data loss occurred, though exfiltration of up to 240MB of data cannot be fully excluded pending forensic analysis.

## 1.1 Incident Summary

| Attribute        | Details                                                                       |
|------------------|-------------------------------------------------------------------------------|
| Incident ID      | INC-2026-0312                                                                 |
| Date Detected    | March 12, 2026 — 02:47 UTC                                                    |
| Date Contained   | March 12, 2026 — 09:29 UTC                                                    |
| Date Resolved    | March 12, 2026 — 21:15 UTC                                                    |
| Affected Systems | WIN-WS-047, WIN-WS-061, VPN Gateway (vpn.novatech.int)                        |
| Affected Users   | 2 confirmed compromised accounts (j.mehta@novatech.in, admin-svc@novatech.in) |
| Attack Vector    | External — Internet-facing VPN gateway (port 1194/443)                        |
| Malware Family   | AgentTesla RAT variant (detected by CrowdStrike Falcon)                       |
| Data at Risk     | 240MB of financial records directory (unconfirmed exfil)                      |
| Business Impact  | 2 workstations offline for 18 hours; VPN service suspended for 4 hours        |
| Root Cause       | No MFA on VPN; weak credentials; outdated endpoint AV signatures              |

**Incident Verdict:** CONTAINED AND ERADICATED. All threat artifacts removed. Systems restored. Preventive controls implemented. No confirmed data exfiltration — forensic investigation ongoing.

## 2. Incident Identification & Alert Analysis

### 2.1 Initial Alert Triggers

The following security alerts were raised by the SOC monitoring stack (SIEM: Wazuh + Splunk) and triggered initial investigation:

| Alert ID | Time (UTC) | Source System          | Severity | Description                                                                             |
|----------|------------|------------------------|----------|-----------------------------------------------------------------------------------------|
| ALT-001  | 02:47:13   | SIEM / Firewall        | CRITICAL | 1,247 failed SSH/VPN login attempts in 8 minutes from IP 185.220.101.47 (TOR exit node) |
| ALT-002  | 03:12:44   | CrowdStrike Falcon     | CRITICAL | Malware execution detected on WIN-WS-047 — AgentTesla dropper (SHA256: a3f8...)         |
| ALT-003  | 03:18:22   | Network IDS (Suricata) | HIGH     | Suspicious outbound C2 beacon — WIN-WS-047 → 91.108.56.182:443 (ET TROJAN rule)         |
| ALT-004  | 03:31:05   | CrowdStrike Falcon     | HIGH     | Lateral movement attempt — WIN-WS-047 scanning internal subnet 10.10.0.0/24             |
| ALT-005  | 03:44:18   | SIEM / AD Logs         | HIGH     | Account j.mehta logged in from new country (RU) 4 minutes after successful VPN auth     |
| ALT-006  | 04:02:51   | DLP / Proxy            | HIGH     | 240MB upload to pastebin-like service — source: WIN-WS-061, user: admin-svc             |
| ALT-007  | 04:15:33   | CrowdStrike Falcon     | MEDIUM   | Persistence mechanism created — scheduled task 'WindowsUpdateHelper' on WIN-WS-047      |

### 2.2 Log Evidence

#### Firewall Log — Brute Force Attempt (ALT-001)

```
2026-03-12T02:47:13Z FIREWALL DENY src=185.220.101.47 dst=203.0.113.10 dport=443
proto=TCP reason=AUTH_FAIL
2026-03-12T02:47:14Z FIREWALL DENY src=185.220.101.47 dst=203.0.113.10 dport=443
proto=TCP reason=AUTH_FAIL
2026-03-12T02:47:14Z FIREWALL DENY src=185.220.101.47 dst=203.0.113.10 dport=443
proto=TCP reason=AUTH_FAIL
... [1,244 similar entries in 8 minutes] ...
2026-03-12T02:55:01Z FIREWALL ALLOW src=185.220.101.47 dst=203.0.113.10
dport=443 proto=TCP reason=AUTH_SUCCESS user=j.mehta
```

## EDR Log — Malware Execution (ALT-002)

```
2026-03-12T03:12:44Z [CrowdStrike] MALWARE_DETECTED host=WIN-WS-047 user=j.mehta
process=invoice_Q1_2026.pdf.exe parent=outlook.exe
SHA256=a3f8c9d1e2b74f5a6c8d0e1f2a3b4c5d6e7f8a9b0c1d2e3f4a5b6c7d8e9f0a1b2
action=QUARANTINE_FAILED reason=process_already_injected
child_process=powershell.exe cmdline=-enc
JABjAGwAaQBlAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0...
```

## Network IDS — C2 Beacon (ALT-003)

```
2026-03-12T03:18:22Z [Suricata] ALERT rule='ET TROJAN AgentTesla C2 Beacon'
src_ip=10.10.0.47 src_port=49821 dst_ip=91.108.56.182 dst_port=443
proto=TCP/TLS bytes_out=1842 bytes_in=412 interval=30s
GeoIP: dst=RU (Russian Federation) ASN=AS49505 Selectel Ltd
```

## 3. Incident Classification

### 3.1 Incident Type & Category

| Attack Category             | MITRE ATT&CK | Evidence                                                               |
|-----------------------------|--------------|------------------------------------------------------------------------|
| Credential Brute Force      | T1110.001    | 1,247 failed auth attempts in 8 min from TOR exit node 185.220.101.47  |
| Phishing / Malware Delivery | T1566.001    | Malicious email attachment (invoice_Q1_2026.pdf.exe) opened in Outlook |
| Malware Execution (RAT)     | T1059.001    | AgentTesla RAT dropper executed via PowerShell encoded command         |
| C2 Beaconsing               | T1071.001    | Outbound HTTPS beacon to 91.108.56.182 every 30 seconds                |
| Lateral Movement            | T1021.002    | Port scan of internal /24 subnet from WIN-WS-047                       |
| Persistence                 | T1053.005    | Scheduled task 'WindowsUpdateHelper' created for reboot survival       |
| Data Exfiltration Attempt   | T1048        | 240MB upload from WIN-WS-061 to external service via HTTPS             |

### 3.2 Severity Assessment

| Factor                  | Rating   | Score | Rationale                                             |
|-------------------------|----------|-------|-------------------------------------------------------|
| Confidentiality Impact  | Critical | 10/10 | PII + financial data potentially exfiltrated          |
| Integrity Impact        | High     | 8/10  | Malware modified system files and created persistence |
| Availability Impact     | Medium   | 6/10  | 2 workstations offline; VPN suspended 4 hours         |
| Scope / Blast Radius    | High     | 8/10  | Active lateral movement; 2+ hosts compromised         |
| Attacker Sophistication | High     | 7/10  | Multi-stage attack; TOR evasion; encoded PowerShell   |

## 4. Containment Strategy

### 4.1 Immediate Containment Actions

The following actions were executed by the SOC team in the order listed, beginning at 03:22 UTC, within 35 minutes of the first critical alert:

| Step | Time (UTC) | Action Type | Action Taken                                                                               |
|------|------------|-------------|--------------------------------------------------------------------------------------------|
| 1    | 03:22:00   | Network     | Isolated WIN-WS-047 from network via VLAN reassignment — host moved to quarantine VLAN 999 |
| 2    | 03:24:15   | Network     | Blocked attacker IP 185.220.101.47 and /24 range at perimeter firewall and edge router     |
| 3    | 03:25:00   | Network     | Blocked outbound traffic to C2 server 91.108.56.182 on all ports at firewall               |
| 4    | 03:27:30   | Identity    | Disabled and force-reset compromised account j.mehta@novatech.in in Active Directory       |
| 5    | 03:28:00   | Identity    | Disabled admin-svc service account; invalidated all active sessions and tokens             |
| 6    | 03:30:00   | Network     | Suspended VPN service to prevent further unauthorized remote access                        |
| 7    | 03:35:00   | Endpoint    | EDR full isolation applied to WIN-WS-061 after lateral movement indicators detected        |
| 8    | 03:40:00   | Identity    | Forced password reset for all accounts with admin privileges (23 accounts)                 |
| 9    | 03:55:00   | Network     | Enabled enhanced logging on all domain controllers and network devices                     |
| 10   | 04:10:00   | Comms       | Incident declared; CISO, IT Director, and Legal notified per IRP protocol                  |

### 4.2 Containment Effectiveness

- C2 communication successfully severed at 03:25 UTC — 7 minutes after IDS alert (ALT-003)
- No additional hosts compromised after isolation of WIN-WS-047 and WIN-WS-061
- VPN suspension prevented any further external attacker re-entry
- Lateral movement halted — internal subnet scan produced no successful connections
- DLP alert (ALT-006) investigated — HTTPS upload intercepted at proxy; content hashing in progress

## 5. Investigation & Root Cause Analysis

### 5.1 Attack Chain Reconstruction

Forensic analysis of logs, EDR telemetry, and memory artifacts reconstructed the following attack chain:

| Stage | Time       | Attack Activity                                                                                                               |
|-------|------------|-------------------------------------------------------------------------------------------------------------------------------|
| 1     | ~01:00 UTC | RECONNAISSANCE — Attacker performs port scan of NovaTech public IP range; identifies VPN gateway on 203.0.113.10:443          |
| 2     | 02:47 UTC  | INITIAL ACCESS (Brute Force) — Automated credential stuffing attack using leaked password list; 1,247 attempts over 8 minutes |
| 3     | 02:55 UTC  | INITIAL ACCESS (Success) — j.mehta account credentials compromised; VPN session established from TOR node 185.220.101.47      |
| 4     | 03:08 UTC  | DELIVERY — Malicious phishing email (invoice_Q1_2026.pdf.exe) sent to j.mehta internal inbox from spoofed supplier domain     |
| 5     | 03:12 UTC  | EXECUTION — j.mehta opens attachment on WIN-WS-047; AgentTesla dropper executes via Outlook, spawns encoded PowerShell        |
| 6     | 03:14 UTC  | DEFENSE EVASION — Malware injects into legitimate svchost.exe process; disables Windows Defender real-time protection         |
| 7     | 03:18 UTC  | C2 ESTABLISHMENT — Encrypted HTTPS beacon to 91.108.56.182:443 every 30 seconds; attacker gains remote shell                  |
| 8     | 03:31 UTC  | LATERAL MOVEMENT — ARP sweep and SMB scan of 10.10.0.0/24; attacker maps internal network topology                            |
| 9     | 03:44 UTC  | CREDENTIAL ACCESS — Mimikatz-like dump of LSASS memory on WIN-WS-047; admin-svc credentials harvested                         |
| 10    | 03:52 UTC  | PRIVILEGE ESCALATION — admin-svc credentials used to access WIN-WS-061 with domain admin rights                               |
| 11    | 04:02 UTC  | EXFILTRATION ATTEMPT — 240MB compressed archive uploaded from WIN-WS-061 to external file-sharing service                     |
| 12    | 04:15 UTC  | PERSISTENCE — Scheduled task 'WindowsUpdateHelper' created on both hosts for C2 re-establishment on reboot                    |
| 13    | 04:30 UTC  | CONTAINMENT — SOC isolation cuts all external C2 and lateral movement paths; attacker loses foothold                          |

## 5.2 Root Cause Analysis

| Root Cause                              | Contributing Factor            | How It Enabled the Attack                                                           |
|-----------------------------------------|--------------------------------|-------------------------------------------------------------------------------------|
| <b>No MFA on VPN Gateway</b>            | Authentication policy gap      | Single-factor auth allowed brute-forced password to grant full VPN access           |
| <b>Weak / Reused Password</b>           | Poor credential hygiene        | j.mehta password matched leaked credential database (HaveIBeenPwned hit)            |
| <b>Outdated AV Signatures</b>           | Delayed endpoint update        | CrowdStrike signatures were 11 days behind; dropper initially bypassed detection    |
| <b>No Email Attachment Sandboxing</b>   | Missing email security control | Malicious .exe attachment reached inbox without detonation analysis                 |
| <b>Excessive Privileges — admin-svc</b> | Least privilege violation      | Service account had domain admin rights; lateral movement trivial once compromised  |
| <b>No Network Micro-Segmentation</b>    | Flat LAN architecture          | WIN-WS-047 could reach all internal hosts; lateral movement unrestricted            |
| <b>No DLP on Outbound HTTPS</b>         | Blind spot in monitoring       | Encrypted upload to external service was only caught by volume anomaly, not content |



## 6. Eradication & Recovery

### 6.1 Eradication Steps

- Quarantined and deleted all malware artifacts on WIN-WS-047 and WIN-WS-061 via CrowdStrike Falcon
- Removed scheduled task 'WindowsUpdateHelper' from both hosts (confirmed persistence eliminated)
- Terminated all injected svchost.exe processes and validated process tree integrity
- Deleted attacker-created registry keys:  
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\WinUpdate
- Revoked all Active Directory sessions and Kerberos tickets for compromised accounts
- Rotated credentials for j.mehta, admin-svc, and all accounts with domain admin privileges
- Blocked attacker IP ranges (185.220.101.0/24) and C2 server (91.108.56.182) at firewall permanently
- Purged malicious email from all mailboxes using Exchange admin purge (ExchangeOnline Remove-Message)

### 6.2 Recovery Steps

| Time (UTC) | System           | Recovery Action                                                                                                    |
|------------|------------------|--------------------------------------------------------------------------------------------------------------------|
| 09:29      | WIN-WS-047       | Full OS reimaging from clean golden image — all user data restored from last clean backup (March 11, 23:00)        |
| 11:15      | WIN-WS-061       | Full OS reimaging — user data restored; admin-svc replaced with application-specific low-privilege service account |
| 12:00      | VPN Gateway      | VPN service restored with MFA enforcement enabled (Azure AD MFA + conditional access policy)                       |
| 13:30      | All Endpoints    | CrowdStrike signatures force-updated; real-time protection verified active on all 94 endpoints                     |
| 15:00      | Active Directory | Stale and service accounts audited; 8 additional unused accounts disabled as precaution                            |
| 18:00      | Email Gateway    | Anti-spoofing (DMARC/DKIM/SPF) policies enforced; attachment sandboxing (Defender ATP) enabled                     |
| 21:15      | All Systems      | Full environment health check completed; incident formally closed; monitoring heightened for 72 hours              |

**Recovery Outcome:** Both affected systems fully restored. VPN reinstated with MFA. No recurrence of C2 activity detected in 72-hour post-incident monitoring window. Forensic disk images retained for legal review.

## 7. Lessons Learned

### 7.1 What Worked Well

- SIEM correlation rule for failed auth spikes detected brute force within 3 minutes of onset
- CrowdStrike Falcon EDR provided rich telemetry enabling rapid attack chain reconstruction
- Suricata IDS C2 beacon rule triggered within 6 minutes of malware establishing C2 channel
- SOC team followed Incident Response Plan; escalation and notifications completed within defined SLAs
- Network isolation via VLAN quarantine was executed in under 15 minutes from first critical alert

### 7.2 What Needs Improvement

- MFA was not enforced on the VPN gateway despite being listed as a recommended control for 6+ months
- CrowdStrike signature update cadence was 11 days behind — dropper initially evaded detection for 2 minutes
- Email security gateway lacked attachment sandboxing — malicious .exe reached user inbox unchallenged
- admin-svc held domain admin rights — violating principle of least privilege; lateral movement was trivial
- DLP solution monitored volume but not content of outbound HTTPS — exfiltration extent remains unconfirmed
- No network segmentation between workstations — single compromised host could scan entire internal /22

### 7.3 Preventive Controls Recommended

| Control                             | Priority | Description                                                                                    |
|-------------------------------------|----------|------------------------------------------------------------------------------------------------|
| Enforce MFA on all remote access    | CRITICAL | Deploy TOTP/FIDO2 on VPN; conditional access policy requiring MFA for all off-network auth     |
| Email Attachment Sandboxing         | CRITICAL | Enable Defender ATP or Proofpoint sandbox; detonate all executable attachments before delivery |
| EDR Signature Auto-Update           | HIGH     | Configure CrowdStrike to auto-update signatures every 4 hours; alert if update > 24h behind    |
| Revoke Admin-Level Service Accounts | HIGH     | Audit all service accounts; enforce least privilege; no service account to hold Domain Admin   |
| Network Micro-Segmentation          | HIGH     | Implement VLAN segmentation; workstations cannot reach other workstations directly             |

|                                    |               |                                                                                              |
|------------------------------------|---------------|----------------------------------------------------------------------------------------------|
| HTTPS Deep Packet Inspection (DPI) | <b>HIGH</b>   | Deploy SSL/TLS inspection at proxy for all outbound HTTPS to detect exfiltration content     |
| Credential Breach Monitoring       | <b>MEDIUM</b> | Integrate HIBP API; alert when employee credentials appear in breach databases               |
| UEBA / Anomaly Detection           | <b>MEDIUM</b> | Enable user and entity behavior analytics; alert on geographic login anomalies               |
| Phishing Simulation Program        | <b>MEDIUM</b> | Quarterly phishing simulations + mandatory security awareness training for all staff         |
| IR Plan Review Cycle               | <b>LOW</b>    | Review and update Incident Response Plan every 6 months; conduct tabletop exercises annually |

## 8. Conclusion & Incident Closure

---

Incident INC-2026-0312 represented a sophisticated, multi-stage attack that successfully exploited three compounding security gaps: the absence of MFA on the VPN gateway, a compromised employee credential, and an email security blind spot that allowed a malware dropper to reach the endpoint. The attack escalated from initial access to active C2 communication and lateral movement within 36 minutes.

The SOC team's rapid detection and coordinated containment response — executing network isolation, account disablement, and C2 blocking within 35 minutes of alert — prevented the attack from achieving its likely objective of large-scale data exfiltration and ransomware deployment. The two compromised systems were fully rebuilt and restored within 18 hours with zero confirmed permanent data loss.

**Key Takeaway:** This incident was preventable. MFA enforcement on the VPN gateway alone would have stopped the attack chain at the first stage. All CRITICAL and HIGH preventive controls must be implemented within 30 days.

### 8.1 Incident Closure Checklist

| Closure Criteria |                                                         | Status      |
|------------------|---------------------------------------------------------|-------------|
| ✓                | Threat fully eradicated from all endpoints              | COMPLETE    |
| ✓                | C2 communication confirmed severed (72-hour monitoring) | COMPLETE    |
| ✓                | All compromised credentials rotated                     | COMPLETE    |
| ✓                | Affected systems rebuilt from clean images              | COMPLETE    |
| ✓                | VPN restored with MFA enforcement                       | COMPLETE    |
| ✓                | CISO and Legal notified per IRP                         | COMPLETE    |
| ...              | Data Protection Officer notified (GDPR/DPDP assessment) | IN PROGRESS |
| ✓                | Forensic disk images preserved for legal review         | COMPLETE    |
| ✓                | Lessons learned documented and distributed              | COMPLETE    |
| ⌚                | Preventive controls implementation plan signed off      | PENDING     |

**Incident Lead Analyst:** SOC Tier-2 Analyst(VIVEK RAJ), Security Operations Center

**Reference Standards:** NIST SP 800-61 Rev 2 | MITRE ATT&CK Framework | ISO/IEC 27035